

Nmap - 2부

핑 무시 (-Pn)

- 호스트 발견 단계에서 핑을 보내지 않고 스캔을 바로 시작하는 옵션
- 핑이 차단된 서버(AWS, 방화벽 뒤)에서도 정상적으로 스캔 가능
- 스캔 자체가 SYN, ACK 등으로 반응을 받기 때문에 핑 없이도 생존 확인 가능
- 단점은 죽은 IP도 끝까지 스캔하려 해서 대역 스캔에서는 매우 느려짐

** 핑이 차단된 서버 만들기

우분투 : 1.1.1.2

칼리 : 1.1.1.3

칼리 -> ping 1.1.1.2

우분투 -> icmp_echo_ignore_all (icmp에코 요청 모두 무시해라)

기본값 : 0 → False

명령어 : (우분투)sudo sysctl -w net.ipv4.icmp_echo_ignore_all=1

```
(root@kali)-[/home/rim]
# ping 1.1.1.2
PING 1.1.1.2 (1.1.1.2) 56(84) bytes of data.
```

=> 요청만 보내고 기다리는 상태

=> 재부팅 하면 원래 상태로 돌아간다.

왜 icmp를 막는것일까?

net discovery를 막으려고(=서버를 보호하기 위하여)

서버의 mac address 노출을 방지하기 위하여

** 영구적으로 설정

sudo nano /etc/sysctl.conf

net.ipv4.icmp_echo_ignore_all=1 을 추가해준다.

적용명령어 : sysctl -p

Timing / Stealth 옵션

- T0~T5: 패킷 간격 조절
- --max-rate: 초당 패킷 수 제한
- --max-retries: 재전송 횟수 제한
- --scan-delay: 패킷 간 휴식 시간
- -Pn: Ping 무시하고 스캔

=> 속도조절용으로 쓰이거나, 방화벽 우회를 목적으로 쓰임

=> 감지되지 않게 하기 위한 요건

Decoy 스캔

**Decoy ?

기만체(미끼) : 진짜를 숨기거나 보호하기 위하여 가짜를 섞어 보여줌

-D RND:5 → 공격자 IP + 랜덤 5개 IP를 섞어 스캔

- 목적: 추적 혼란 유발 (로그에 여러 IP가 동시에 찍힘)
- 방화벽 우회 기능은 없음 (우회X, 혼란용 기술)
- 과도하게 사용 시 오히려 탐지 시스템에서 더 잘 보일 수 있음
- 정리: “누가 진짜 공격자인지 헷갈리게 만드는 옵션”

출발지 Spoofing (-S)

: 출발지 IP 위조 !

- 스캔 패킷의 출발지 IP를 ‘내가 아닌 다른 IP’로 바꾸는 옵션
- 목적: 추적을 어렵게 만들거나 특정 상황에서 응답 흐름을 바꾸기 위함(교란용)

=> 단점: 정상적인 응답은 스푸핑된 IP로 돌아가므로 내가 받지 못함

Decoy, Spoofing 차이점

Spoof(-S) = 진짜 스푸핑

- IP 바꿔치기
- 응답을 받아야 의미 있음
- ARP / 라우팅 제약 존재
- 완전 다른 대역 스푸핑은 거의 불가능

Decoy(-D RND:x) = 페이크 트래픽 생성

- 응답을 받을 필요 없음
- ARP 필요 없음
- 랜덤 IP 아무거나 막 씀
- “로그 교란용”

TXT 기반 자동화 스캔 구조

- 대상 목록을 txt로 관리하고 한 번에 불러오는 구조

(-iL [대상_IP_목록.txt])

- 포트 목록도 txt로 관리해 자동 반영 가능

Ex) -p \$(cat [포트_목록.txt]) or

-p \$(paste -sd "," [포트_목록.txt])

- 결과는 파일로 저장해 후처리·비교 가능 (-oN / -oG / -oX)

NES

- Nmap에 내장된 자동 분석 스크립트 엔진
- 서비스 정보수집, 인증방식 확인, 간단한 취약점 점검까지 자동 실행
- script 옵션으로 원하는 스크립트를 선택해 추가 기능 실행 가능

```
ex) --script default / --script vuln / --script vuln /  
    --script ssh-auth-methods
```